

CruDoc Edge Case Analysis Report

A Plain-Language Clinical & Technical Risk Assessment Across All 15 Platform Modules

Audience: Non-Technical Stakeholders & Medical Team

Scope: Mobile & Web App Architecture

Coverage: 15 Core Modules

Classification: Comprehensive System Review

Risk
Ratings:

 **High**

Critical risk (Data loss / Medical impact / Security)

 **Medium**

Operational friction or silent retry

 **Low**

Minor UI/UX cosmetic nuance

 **Handled**

Existing safeguard verified

What is this? This report lists situations that could cause unexpected behavior in the CruDoc app. Think of "edge cases" as rare but realistic scenarios — like a doctor losing internet mid-save, or a patient having a phone number with unusual characters. For each feature, we explain **what could go wrong**, **who it affects**, and **how serious it is**.

1. Login & Authentication

WHAT THIS FEATURE DOES

Doctors log in using email/password, Google Sign-In, or phone OTP. The app checks if the doctor exists in the database and is not disabled.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Doctor logs in from two phones at the same time	Both devices can operate simultaneously. If both make changes to the same patient while offline, the last one to sync wins — the first doctor's changes could be silently overwritten.	● Medium
2	Super Admin disables a doctor's account while the doctor is already logged in	The doctor stays logged in until they close and reopen the app. They can keep working during that session — the "disabled" check only runs at login time, not continuously.	● Medium
3	Doctor signs up directly (email/password) without Super Admin creating them first	The signup creates a Firebase Auth account AND a Firestore users record automatically. This bypasses the Super Admin approval flow — anyone with the signup page can create an account.	● High
4	Internet drops exactly during the login Firestore check	The app might show "User does not exist" even though the doctor is valid, because it couldn't reach the database to verify. The error message is misleading.	● Medium
5	Doctor changes their password via Firebase Console or "Forgot Password"	The "Remember Me" feature stores the email but not the password. Login will simply fail with a generic error — the doctor won't know their old password no longer works.	● Low

2. Patient Records

WHAT THIS FEATURE DOES

Doctors add, edit, view, and delete patient profiles. Patient data is stored locally (SQLite) and synced to the cloud (Firestore). Sensitive fields like names and phone numbers are encrypted.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Doctor adds a patient while completely offline	The patient is saved locally and works fine. But if the doctor uninstalls the app or switches phones before internet returns, that patient data is permanently lost — it never reached the cloud.	● High
2	Two doctors accidentally share the same Firebase Auth account	All patient data is scoped to doctorId. If two people use the same login, they see each other's patients. There's no warning or prevention mechanism for shared accounts.	● High
3	Patient name contains special characters (emojis, Arabic script, very long names)	The encryption layer handles arbitrary strings, so this should work. However, the UI may truncate or display oddly for extremely long names (200+ characters). No explicit character limit is enforced on the input form.	● Low
4	Deleting a patient who has visits, invoices, and homeopathy case sheets linked	The patient is "soft-deleted" (marked as deleted, not actually removed). However, linked data (visits, revenue entries, case sheets) is NOT cascade-deleted. Orphaned records remain in the database and sync service forever.	● Medium
5	Encryption key is lost or corrupted in secure storage	Patient names, phone numbers, and notes would appear as unreadable encrypted text (like enc:v1:abc123...) instead of crashing. The doctor would need to re-log in to re-fetch the key. If the key in Firestore doctor_keys is also lost, the data is permanently unreadable .	● High
6	Doctor searches for a patient with a misspelled name	Search appears to be basic text matching. There's no fuzzy search or "did you mean?" suggestion. A typo like "Amit" vs "Amith" would return no results.	● Low

3. Appointments & Visits

WHAT THIS FEATURE DOES

Doctors schedule, track, and complete patient visits. Supports both clinic (in-person) and home visits.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Doctor schedules two patients at the exact same time	There's no time-slot conflict check. Both appointments are accepted without any warning. The doctor discovers the clash only when looking at the calendar.	● Medium
2	Visit is created for a patient who was just deleted	The soft-delete doesn't prevent new visits from being linked to the deleted patient. The visit appears with the patient name, but opening the patient profile may show "not found."	● Medium
3	Doctor marks a visit as "completed" but forgets to add treatment notes	The visit is saved as completed with empty treatment fields. There's no prompt or validation requiring the doctor to fill in clinical details before marking complete.	● Low
4	Time zone changes (doctor traveling, or phone auto-adjusting)	Visit timestamps use the device's local time (<code>DateTime.now()</code>). If the doctor's phone clock is wrong or they travel across time zones, visits may appear on the wrong date in the schedule.	● Medium

💰 4. Revenue & Invoices

WHAT THIS FEATURE DOES

Doctors record income and expenses, generate invoices, and track pending payments. Revenue amounts are encrypted before cloud sync.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Doctor enters a revenue amount of ₹0 or a negative number	The app correctly blocks amounts ≤ 0 with a validation error ("amount must be greater than zero"). This is handled well. 	 Handled
2	Doctor records revenue while logged out (session expired)	The revenue repository falls back to <code>doctorId = 'anonymous'</code> instead of throwing an error. This means the revenue entry is saved locally but tagged to "anonymous" — it will never sync to the correct doctor's cloud data, and could theoretically be visible to any user on that device.	 High
3	Revenue amounts stored as encrypted strings fail to decrypt	If decryption fails, the amount defaults to <code>0.0</code> . This means financial reports would show ₹0 for entries that actually had money — misleading but not crashing. The doctor wouldn't know their data is corrupted.	 Medium
4	Very large amounts (e.g., ₹99,99,99,999.99)	The amount is stored as a <code>double</code> , which can represent numbers up to ~ 9 quadrillion. Practically no issue, but the UI might not format Indian currency correctly for very large numbers (lakhs/crores formatting).	 Low
5	Invoice PDF generated with patient data that contains injection characters	The PDF generation uses the <code>pdf</code> package which renders text directly — there's no HTML interpretation. CSV exports, however, do sanitize for formula injection. PDF generation is safe. 	 Handled

5. Inventory / Medicine Stock

WHAT THIS FEATURE DOES

Doctors manage their medicine stock, track quantities, set reorder thresholds, record stock adjustments, and get low-stock alerts.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Stock goes negative (doctor dispenses more than available)	There's no guard preventing stock from going below zero. A stock adjustment of -100 on a medicine with 50 units would result in -50 stock — the UI would display it, but it's medically and logistically nonsensical.	● Medium
2	Medicine added with an expiry date in the past	No validation prevents adding a medicine with yesterday's expiry date. It would show up normally in inventory without any expired warning until the alert system checks.	● Low
3	Same medicine name added twice	No duplicate name check exists. A doctor could accidentally create "Paracetamol 500mg" twice, leading to split stock tracking and confusing reports.	● Medium
4	OCR scans a blurry medicine label	The OCR service would return garbage text or partial data. There's no confidence-score check or "this scan doesn't look right" warning. The doctor could save incorrect medicine data without realizing.	● Medium

 6. WhatsApp Notifications

WHAT THIS FEATURE DOES

After booking an appointment, the app sends an automated WhatsApp message to the patient confirming the date, time, and doctor details.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Patient has no phone number, or an invalid one (e.g., "N/A", "0000")	The app correctly detects this and skips the notification with a log message: "Patient X has no valid WhatsApp number." 	 Handled
2	WhatsApp API access token expires or is revoked	The token is loaded from an environment variable. If it's empty or expired, the API call fails silently — the visit is still created successfully, but no notification is sent. The doctor has no way to know the notification failed.	 Medium
3	Same notification sent twice (duplicate check-in or retry)	The app has idempotency protection — it checks if a notification was already sent for that visit ID and skips duplicates. 	 Handled
4	Patient's phone number is a landline	WhatsApp requires a mobile number. The API call would fail with an error, but the failure is silently caught. The doctor wouldn't know the patient didn't receive the message.	 Medium
5	WhatsApp template not approved by Meta	The API would return a "template not found" error. Since errors are swallowed silently (catch (__) {}), the doctor has no feedback that their template needs approval.	 Medium

 7. Campaigns (Bulk WhatsApp & Email)

WHAT THIS FEATURE DOES

Doctors send health tips, announcements, or follow-up reminders to groups of patients via WhatsApp or Email.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Campaign sent to 500 patients, internet drops at patient #200	The first 200 get their message. The remaining 300 are marked as "queued" but the campaign shows as "processing" forever. There's no automatic retry mechanism when internet returns.	 High
2	Doctor sends a campaign while logged out	The campaign saves with <code>doctorId = 'anonymous'</code> . It would either fail silently or, worse, create orphaned campaign records not tied to any doctor.	 Medium
3	Patient unsubscribes from WhatsApp messages	There's no opt-out or unsubscribe mechanism built into the app. The doctor would keep sending messages, potentially violating WhatsApp's spam policies and risking their business account being suspended.	 High
4	Email campaign to patients without email addresses	Those patients would simply be skipped in the dispatch loop. However, the final "delivered" count might be confusing — "sent to 45 of 100 patients" without explaining why 55 were skipped.	 Low

8. AI Chatbot

WHAT THIS FEATURE DOES

An AI-powered assistant that answers the doctor's questions about app features, helps navigate the dashboard, and provides clinical workflow tips.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	No internet and no API key configured	The chatbot falls back to a built-in offline response engine that uses keyword matching. Responses will be generic but functional. ✓	Handled
2	Doctor asks a medical question expecting clinical advice	The AI is not designed to give medical advice — it's a CruDoc feature assistant. But there's no explicit guardrail preventing it from answering "What's the dosage of Amoxicillin?" if the AI model responds. This could be a liability risk.	High
3	Very long conversation (100+ messages)	The entire chat history is sent to the AI on each message. This could exceed the AI model's token limit, causing errors or truncated responses. There's no conversation length management or pruning.	Medium
4	Doctor types sensitive patient information into the chatbot	The message is sent to Google's Gemini API servers. Patient PHI (names, conditions) would leave the device and reach Google's cloud — potentially a HIPAA/privacy concern if not disclosed.	High

9. AI Scribe (Voice-to-Prescription)

WHAT THIS FEATURE DOES

Records a doctor-patient consultation, sends the audio to Google's Gemini AI, and generates structured clinical notes (symptoms, diagnosis, medicines, advice).

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Recording is too short (< 5 seconds) or silent	The app correctly checks for a minimum audio size (~10KB). Tiny recordings are rejected with an appropriate error. ✓	Handled
2	Noisy clinic environment (crying babies, traffic)	The AI may misinterpret background noise as speech and include incorrect symptoms or medicine names. The "confidence note" field exists for the AI to flag uncertainty, but doctors may not check it.	Medium
3	AI hallucinates a medicine the doctor never mentioned	This is the most dangerous edge case. Despite the system prompt saying "only extract what was ACTUALLY SAID," AI models can still hallucinate. A wrong medicine in the prescription could harm a patient. The doctor must always review the AI output before saving.	High
4	Consultation in a language other than English (Hindi, Marathi mix)	The AI's accuracy with code-switching (mixing languages) depends on the model. It may miss or mistranslate terms. No language selection or warning is provided.	Medium
5	Audio file upload to Firebase Storage fails	The service returns null for the storage path and proceeds to process locally if possible. However, if the entire processing pipeline fails, the doctor loses the recording with no way to retry.	Medium

 10. Walk-In Queue System

WHAT THIS FEATURE DOES

Manages a daily walk-in patient queue with token numbers, priority levels, and status tracking (waiting → in-progress → completed/skipped).

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Same patient checks in twice on the same day	There's no duplicate check-in prevention. The patient gets two tokens, which wastes a slot and confuses the queue.	● Medium
2	Doctor checks in a patient who has been archived/deleted	The app correctly catches this with a <code>QueuePatientArchivedException</code> and blocks the check-in. ✅ However, if the check fails due to being offline, it lets the check-in proceed (by design — "never let a side read block the write").	⚠️ Partial
3	Token numbers reset — when?	Tokens reset daily based on the device's local date. If the doctor's phone date is wrong (e.g., set to yesterday), tokens could restart at 1 mid-day, causing duplicate token numbers.	● Medium
4	Queue is very long (100+ patients)	No limit on queue size. The UI might slow down rendering 100+ token cards, especially on older phones.	● Low

🌿 11. Homeopathy Case Taking

WHAT THIS FEATURE DOES

A 14–section clinical case taking worksheet for homeopathic practitioners, covering everything from chief complaint to miasmatic analysis and remedy selection.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Doctor fills out 13 sections, then accidentally closes the app	If they tapped "Save Draft" before closing, data is preserved. If not, all 13 sections of work are lost — there's no auto-save or "unsaved changes" warning.	● High
2	Male patient's case sheet shows the "Female Reproductive" section	The section is conditionally shown based on patient gender. If gender is empty or null, the section is hidden (defaults to hiding). ✅	✅ Handled
3	Doctor creates a case sheet for a patient who already has one	A second case sheet is created with a new ID. Both exist side-by-side. The UI shows the most recent one, but older sheets are not accessible from the patient details screen — they're effectively hidden.	● Medium
4	Very long text in "Peculiar Symptoms" or "Repertorization Notes"	SQLite TEXT type has no practical limit. The UI text fields scroll properly. However, syncing very long text to Firestore (which has a 1MB document limit) could fail for extreme cases.	● Low

12. Offline Sync (SQLite ↔ Firestore)

WHAT THIS FEATURE DOES

The app saves all data locally first (SQLite), then syncs to the cloud (Firestore) when internet is available. This is the backbone that makes the app work without constant internet.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Doctor works offline for 3 days, then connects	All 3 days of data syncs in one batch. This should work, but if there are hundreds of changes, the batch upload could take minutes and might time out. There's no progress indicator for sync.	 Medium
2	Two devices edit the same patient while both are offline	When both reconnect, the "last writer wins" — whichever device syncs second overwrites the first. There's no conflict detection or merge strategy. Changed data from the first device is silently lost.	 High
3	Sync runs while the doctor is actively editing a record	The sync could upload a half-edited record. There's no lock or "dirty" flag that tells the sync service "this record is currently being edited, wait."	 Medium
4	Firestore quota exceeded (too many reads/writes)	The sync would fail silently for that batch. Records stay marked as "pending" locally and would retry next time. But there's no alert to the doctor that sync is failing.	 Medium
5	App is force-killed during a sync upload	Records that were mid-upload are left in "pending" state. On next app launch, they'll be retried. However, if the Firestore write succeeded but the local "mark as synced" step didn't run, duplicates could be created in Firestore.	 Medium

13. Data Encryption & Security

WHAT THIS FEATURE DOES

Sensitive patient data (names, phone numbers, clinical notes, revenue amounts) is encrypted before leaving the device. Each doctor gets their own unique encryption key.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Doctor's phone is factory-reset	The local encryption key cache (in Secure Storage) is wiped. However, the "wrapped key" is stored in Firestore (doctor_keys/{uid}), so it can be re-fetched on login. Data is recoverable. 	 Handled
2	The _appPepper constant in the code is extracted by a hacker	The pepper is embedded in the app binary and can be extracted. An attacker with access to both the app binary AND the Firestore database could theoretically decrypt patient data. This is acknowledged in the code comments as a known limitation.	 Medium
3	Encryption is bypassed because the key hasn't loaded yet	If <code>FieldCipher.encrypt()</code> is called before the encryption key is loaded, it returns the plaintext unchanged. This means data could be stored unencrypted in Firestore if there's a race condition during app startup.	 Medium
4	Multiple doctors on a shared/kiosk device	Each doctor's key is cached separately by doctor ID. Logging out clears the in-memory key but NOT the Secure Storage cache. A technically skilled person with physical device access could potentially extract cached keys for all doctors who ever logged in on that device.	 Medium

14. Super Admin Panel

WHAT THIS FEATURE DOES

A web-based control panel for the platform owner to manage all doctors, approve subscriptions, view analytics, and control feature access.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Super Admin disables a doctor who has patients mid-consultation	The doctor continues working in the current session. Data saved during that session syncs normally. The block only takes effect on next login.	 Low
2	Two Super Admins make conflicting changes at the same time	There's no optimistic locking. Both changes save, and the last one wins. For example, one admin approves a subscription while another rejects it — the final state depends on timing.	 Medium
3	Super Admin creates a doctor with a specialization not in the dropdown list	The specialization dropdown has a fixed list (General Physician, Cardiologist, etc.) but does NOT include "Homeopath" or "Physiotherapist." If the Super Admin types a custom value, the specialty resolution would work via fuzzy matching, but the dropdown UI doesn't support it.	 Medium

15. App Updates

WHAT THIS FEATURE DOES

The app checks for new versions via GitHub Releases and prompts the doctor to update.

EDGE CASES TO WATCH

#	SCENARIO	WHAT COULD HAPPEN	SEVERITY
1	Doctor ignores the update for weeks	Update checks are throttled to once every 6 hours. The banner keeps showing. But there's no force-update mechanism for critical security patches — the doctor can keep using an old, potentially vulnerable version indefinitely.	 Medium
2	Download fails mid-update (internet drops)	The downloaded partial file would be corrupted. On Android, the installer would reject it. On Windows, the update installer may crash. There's no download resume or integrity check (e.g., checksum verification) visible in the code.	 Medium

Summary: Top Priority Items

These are the edge cases that need the most urgent attention:

PRIORITY	ISSUE	FEATURE	WHY IT MATTERS
 Critical	Signup bypasses Super Admin approval	Auth	Anyone can create an account and access the platform
 Critical	Revenue saves under 'anonymous' when logged out	Revenue	Financial data could be lost or misattributed
 Critical	No auto-save in Homeopathy case sheet	Homeopathy	30+ minutes of clinical data entry could be lost
 Critical	AI Scribe could hallucinate medicines	Scribe	Wrong prescription data could harm patients
 Critical	Doctor PHI sent to Google servers via chatbot	Chatbot	Privacy/HIPAA compliance risk
 Critical	Offline sync conflict: last writer wins	Sync	Patient data could be silently overwritten
 Critical	Campaign stuck at "processing" if internet drops	Campaigns	No retry, no recovery, misleading status
 Critical	No WhatsApp opt-out mechanism	Campaigns	Risk of Meta account suspension
 Critical	Encryption key loss = permanent data loss	Security	If both device and Firestore key are lost, data is unrecoverable